ProfiNET on the Festo machine

For this assignment I looked at the ProfiNET traffic of the dispense station. I used the Wireshark capture file that was given (festoFactoryWireshark - IO being used.pcapng) and I opened it in Wireshark. Below I answer the parts of the assignment one by one.

1. How ProfiNET works (the basics)

ProfiNET is a network that factories use so a PLC can talk to its sensors and actuators. It runs on normal Ethernet, so it uses the same cables, switches and network cards as a normal computer network. That is handy, but it also means you can read the traffic with Wireshark like any other network.

The main parts are:

- The PLC. This is the boss (the controller). It runs the program and decides what the outputs do.
- The IO device. This is the slave. It reads the inputs (sensors) and sets the outputs (actuators) and sends the values back to the PLC.
- The engineering PC or HMI, used to program and watch the machine.

ProfiNET has a few types of messages. In Wireshark you filter them with pn_. The two important ones are:

- pn_io: the normal data between the PLC and the IO device. These messages are sent all the time, very fast, and they carry the real inputs and outputs.
- pn_dcp: this is used when the PLC searches for devices and gives them a name and IP address. It only happens when you start up or restart a device.

An important point: these pn_io messages are not encrypted and there is no password or signature on them. So anyone on the same network can read them, and also copy them.

2. What I found in the capture (Wireshark monitoring)

I opened the capture and used the filter pn_io. This is what I saw:

- The file has about 116.000 packets over about 115 seconds.
- Almost all of them (about 99 percent) are ProfiNET real time messages.
- There are two devices doing all the talking:
- The PLC: IP 172.21.2.1, MAC 30:b8:51:33:7e:c7. This is station 2.
- The IO device: MAC 4c:e7:05:4b:46:4b. With the lldp filter I could even read its name and type: it is a Siemens ET200SP (IM155-6PN/2 HF) and its ProfiNET name is "pniodispense". That is the IO block on top of the dispenser.

- The PLC and the device send a message to each other about every 2 milliseconds (so 500 times per second). Both directions use FrameID 0x8000.
- I did not see any pn_dcp messages. That makes sense, because the machine was already running in this capture. You only see pn_dcp when a device is powered off and on again. To capture that you would have to pull the power of the IO block for a moment, like the assignment says.

So the whole machine is controlled by these small messages, sent 500 times a second, with no protection on them.

3. Which attacks have been done against ProfiNET (with sources)

Because the messages have no protection, researchers have found several attacks. These are real and written about:

- Scanning the network with pn_dcp. You send one request and every device answers with its name, type and IP. Now you know the whole machine.
- Spoofing with pn_dcp. You can rename a device or change its IP, which breaks the link with the PLC and the device goes offline.
- Man in the middle with ARP spoofing. You put yourself between the PC and the PLC and can read or change the traffic.
- Replay attack. You record the normal messages and send them again later. Because there is no protection, the receiver can believe the old (recorded) data.
- Fake messages / flooding (denial of service). You send your own 0x8000 messages faster than the real ones, or you flood the device so it loses the connection and stops.

Sources I used:

- Pfrang and Meier, "Detecting and preventing replay attacks in industrial automation networks operated with PROFINET IO", 2018.
- Akerberg and Bjorkman, "Exploring Security in PROFINET IO", 2009.
- Paul, Schuster and Konig, "Towards the Protection of Industrial Control Systems ... PROFINET IO", 2013.
- Mehner and Konig, "Attacking Profinet IO Automation Networks Using DCP", 2019.
- PROFINET Security Guideline (PI organisation).

4. How I want to attack the machine and my goal

My goal is to show that you can mess with the dispenser if you are on the same network. I want to show two things:

- Denial of service: make the IO device stop or go into error, so the dispenser does not work anymore.

- Replay/spoofing: make the PLC or the device believe data that is not true (for example that everything is fine, while it is not).

I can do this because I already have everything I need from the capture: the FrameID (0x8000), both MAC addresses, the IP addresses and the timing (2 ms). Nothing is encrypted, so I do not have to crack anything.

The plan would be:

1. Connect my laptop to the switch in the cabinet.
2. Record the normal pn_io messages (I already have them in the capture).
3. Send them again (replay), or send my own messages faster than the real ones.
4. Watch what happens on the HMI and in Wireshark.

Tools for this are normal and free: Wireshark to record, and tcpreplay or Scapy to send the messages again.

5. Trying the replay attack (on the capture)

Because I only had to work with the capture file, I did the replay part on the capture itself. This already shows that the attack works:

- The messages are complete and readable. Every message already has the right MAC address, the right FrameID and the data. So a recorded message is also a message you can send again, you do not have to build anything.
- The only "freshness" check is a small counter in the message (the cycle counter) and the data is always marked as valid. The receiver mostly only checks that messages keep coming in time (the watchdog). So an old, recorded message still looks fine.
- The timing is easy to copy, because it is just every 2 ms.

So the recording itself is already the proof: these messages can be sent again as they are.

If you really wanted to replay it on a test setup (not the real running machine), you would:

- In Wireshark, filter pn_io and use File, Export Specified Packets to save only these messages.
- Play that file back on the network with tcpreplay, or send it with Scapy, keeping the same MAC, FrameID and 2 ms timing.
- The device would then act on the old recorded data, or the real and fake messages would clash and the device would go into error (which stops the dispenser).

I did not run this on the real machine, because on a running machine this can really stop it and that is not safe. But the capture shows that nothing stops you from doing it.

Conclusion

The dispense station is fully controlled by ProfiNET messages that have no password and no encryption. Anyone who can plug into the switch in the cabinet can read them, copy them and send them again. So the main risk is that someone with access to the network can stop the machine or feed it false data. The best protection is not on the messages themselves (that is not really possible), but around them: keep the OT network separate from the normal network, lock the switch ports, and keep the cabinet physically locked.

Sources

- Pfrang and Meier, Detecting and preventing replay attacks in industrial automation networks operated with PROFINET IO, 2018.
- Akerberg and Bjorkman, Exploring Security in PROFINET IO, COMPSAC 2009.
- Paul, Schuster and Konig, Towards the Protection of Industrial Control Systems, DIMVA 2013.
- Mehner and Konig, Attacking Profinet IO Automation Networks Using DCP, DIMVA 2019.
- PROFIBUS and PROFINET International, PROFINET Security Guideline.